

PROJECT

14

THREAT DETECTION WITH GUARDDUTY

SECURITY SERVICE

Prepared by:
Amrize JK
Certified Solutions Architect Associate

Objective

To simulate a real-world attack scenario by deploying a vulnerable web application, exploiting it to steal data, and detecting the malicious activity using Amazon GuardDuty. This project demonstrates how AWS security services identify and respond to potential threats through automated monitoring and alerts.

Services

Amazon GuardDuty: Detects suspicious AWS activity automatically.

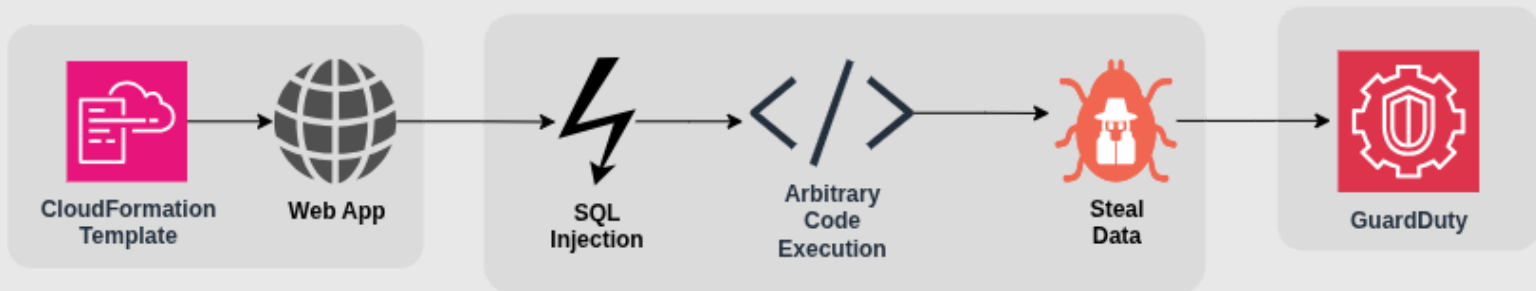
Amazon CloudFront: CDN that adds edge traffic telemetry.

Amazon S3: Stores artifacts and archived logs.

AWS CloudFormation: Deploys reproducible infrastructure as code.

OWASP Juice Shop: Intentionally vulnerable web app for testing.

Architecture Diagram



A vulnerable web app is deployed from a CloudFormation template, an attacker exploits it via SQL injection that leads to arbitrary code execution and data exfiltration, and the resulting malicious activity is picked up by Amazon GuardDuty (using AWS telemetry) for detection and investigation.

Steps to Implement

- 1. Deploy the stack with CloudFormation:** `aws cloudformation deploy --template-file template.yaml --stack-name juice-shop --capabilities CAPABILITY_NAMED_IAM`.
- 2. Confirm the web app is reachable:** `curl -I https://<your-app-url>` or open the ALB/CloudFront URL in a browser and verify headers.
- 3. Create or use a test user and record credentials:** register a user via the Juice Shop UI or provision one via your deployment and store securely.
- 4. Perform the exploit:** run a controlled SQL injection or crafted request against a vulnerable endpoint (e.g., with curl or your proxy tool) to trigger arbitrary code execution.
- 5. Simulate data exfiltration with stolen credentials:** use the compromised credentials to access sensitive endpoints or download from S3 (e.g., `aws s3 cp s3://<bucket>/sensitive.txt .`).
- 6. Check GuardDuty findings and alerting:** list findings in the console or via CLI (`aws guardduty list-findings` / `aws guardduty get-findings`) and review related CloudTrail/CloudWatch logs for correlation.

Story Time

Juice Shop (The Mischievous Market): a lively bazaar full of shiny stalls and intentionally loose lockboxes, perfect for teaching apprentices how attackers think and how defenders act.

CloudFormation (The Master Builder): a wise architect with a scroll of blueprints who waves a wand and conjures the whole kingdom exactly the same way every time.

GuardDuty (The Night Watch): a vigilant sentry perched on the ramparts, scanning footprints and unusual shadows, whispering “alert!” when something suspicious stirs.

S3 (The Treasure Chest): a set of locked chests where the kingdom stores artifacts, some marked public, some secret; the apprentice learns which chests must stay sealed.

IAM (The Keymaster): keeper of permissions and keys, hands the right keys to the right citizens and revokes them when a contract ends.

OWASP Juice Shop (The Training Grounds): a mischievous playground created to safely trigger known tricks so defenders can practice detection, response, and lessons learned.

BY
AMRIZE J.K

THANK YOU!

